

CYBERSECURITY RISK ASSESSMENT

Executive Summary

Prepared for: F-corp | Date: June 2026 | Analyst: Jerome Jones

1. Purpose of This Report

This report summarizes the findings of a cybersecurity risk assessment conducted for F-corp , a small e-commerce business. The goal is to identify the most significant threats to the company's operations, customer data, and financial stability, and to provide clear, actionable recommendations that leadership can act on immediately.

This report is written for non-technical leadership. Technical details are available in the full Risk Register and Control Recommendations documents upon request.

2. Current Risk Snapshot

The assessment identified 10 risks across 8 critical business assets. The breakdown below reflects the severity distribution:

CRITICAL Risks 3	HIGH Risks 4	MEDIUM Risks 3	LOW Risk 0
------------------	--------------	----------------	------------

WARNING: 3 Critical risks require immediate action. Failure to address these within 30 days significantly increases the probability of a breach.

3. What Is at Stake - Financial and Reputational Exposure

The table below translates each major risk into business terms.

Risk Area	Potential Cost to Business	Probability
Customer Data Breach	\$120k-\$1.4m	25%-30%
Payment Gateway Attack	\$10.22 million	22%
Admin Account Compromise	\$500k-\$2.5m	35%-50%
No Incident Response Plan	\$1m-\$4m	60%-80%

4. Top Priority Actions - What Leadership Must Approve

The following five actions address the highest-risk vulnerabilities identified. These are prioritized by risk score and ease of implementation:

#	Action Required	Timeline	Estimated Cost
1	Enable Multi-Factor Authentication (MFA) on all admin accounts	<i>immediate</i>	\$0–\$6 /month (<i>Microsoft Authenticator — free tier available</i>)
2	Encrypt all customer PII data at rest and in transit	<i>immediate</i>	\$50–\$200 / month (<i>Cloud encryption via AWS KMS or equivalent</i>)
3	Deploy Web Application Firewall (WAF) on e-commerce platform	30 days	\$20–\$50 /month (<i>AWS WAF basic tier</i>)
4	Create a written Incident Response Plan	60 days	\$0 internal / \$1,000–\$5,000 one-time (<i>external consultant option</i>)
5	Conduct phishing awareness training for all staff	60 days	\$100–\$500 / year (<i>KnowBe4 or equivalent; free internal option available</i>)

5. Critical Gaps in Current Security Posture

The NIST Cybersecurity Framework assessment revealed three areas with no controls currently in place. These represent the company's most dangerous blind spots:

Gap Identified	Business Risk	Recommended Fix
No Incident Response Plan	<i>Without an incident response plan, the company will respond slowly and inconsistently to cyberattacks. This can lead to prolonged downtime, greater data loss, higher recovery cost, and serious damage to the company's reputation. It also increases the risk of regulatory fines if breaches are not handled properly</i>	<i>Create and document a formal incident response plan that outlines roles, responsibilities, and step-by-step actions for detecting, responding to incidents. Regularly test the plan with simulations to ensure the team is prepared.</i>
No Formal Asset Inventory Process	<i>If the company does not know what systems, devices, and data it owns, it cannot properly secure them. This creates blind spots where vulnerabilities can go unnoticed, increasing the likelihood of cyberattacks and unauthorized access</i>	<i>Implement an asset inventory system to track all hardware, software, and data assets. Keep it continuously updated and classify assets based on importance so security efforts can be prioritized effectively</i>
No Disaster Recovery Plan	<i>Without a disaster recovery plan, the company may not be able to restore systems and data after events like cyberattacks, hardware failure or natural disasters. This can result in extended downtime, lost revenue, and potentially permanent data loss.</i>	<i>Develop a disaster recovery plan that includes data backups, recovery procedures, and defined recovery time objectives (RTOs). Regularly test backups and recovery processes to ensure the systems can be restored quickly.</i>

6. Analyst Assessment

Analyst Notes & Overall Assessment

The company is currently exposed to serious security risk due to missing basic protections for its systems and customer data. Sensitive information could be accessed or stolen, and the business may not be able to respond effectively to an attack or system failure. These gaps increase the likelihood of financial loss, downtime, and damage to the company's reputation. Without taking immediate action, a security incident could significantly disrupt operations and impact customer trust.

7. Recommended Next Steps

- Schedule a 30-minute leadership review of this report within 2 weeks
- Assign an owner to each Priority 1 action item
- Establish a quarterly GRC review cycle to reassess risk scores
- Begin drafting an Incident Response Plan
- Conduct phishing awareness training within 60 days

*This assessment was conducted as part of a GRC portfolio project. All company details are fictional.
Framework references: NIST CSF 2.0, PCI-DSS v4.0, FTC Act.*